

SEE ALSO Newsletter of April 10, 2024

[doc. web n. 10001279]

Provision of February 22, 2024

Register of provisions

n. 97 of February 22, 2024

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting held today, attended by
Prof. Pasquale Stanzione, President, Prof.
Ginevra Cerrina Feroni, Vice President, Dr.
Agostino Ghiglia and Attorney Guido Scorza, members, and
Counsel Fabio Mattei, Secretary General;

HAVING REGARD TO Regulation (EU) 2016/679 of the European Parliament
and of the Council, of April 27, 2016, concerning
the protection of natural persons with regard to
the processing of personal data, as well as the free
movement of such data and repealing Directive
95/46/EC, "General Data Protection Regulation" (hereinafter "Regulation");

HAVING REGARD TO Legislative Decree No. 196 of June 30, 2003, containing
"Code regarding the protection of personal data,
containing provisions for the adaptation
of the national legal system to Regulation (EU)
2016/679 of the European Parliament and of the Council, of
April 27, 2016, concerning the protection of
natural persons with regard to the processing of personal data,
as well as the free movement of such data and repealing Directive 95/46/EC (hereinafter
"Code");

HAVING REGARD TO Regulation No. 1/2019 concerning
internal procedures with external relevance,
aimed at carrying out the tasks and
exercising the powers delegated to the Guarantor for the
protection of personal data, approved by
resolution No. 98 of April 4, 2019, published in
G.U. No. 106 of May 8, 2019 and on www.gpdp.it, doc. web
n.9107633 (hereinafter "Guarantor Regulation No.
1/2019");

HAVING REGARD TO the documentation on file;
HAVING REGARD TO the observations made by the Secretary
General pursuant to Article 15 of the Guarantor
Regulation No. 1/2000 on the organization and
functioning of the office of the Guarantor for the
protection of personal data, on www.gpdp.it, doc.
web n.1098801;

Reporting by Dr. Agostino Ghiglia;

PREAMBLE

1. Complaints, personal data breaches, and
investigative activity

The Authority has received two complaints and two notifications of
breach regarding the processing of personal data

carried out by the South Tyrol Health Authority (hereinafter the Authority or ASDAA) through the corporate health dossier. In particular, repeated accesses to the dossier by healthcare personnel who, although authorized to process, were not involved in the care process of the individuals to whom the health dossiers referred were reported. With reference to the first complaint submitted by Mr. XX, who complained of repeated accesses to the corporate health dossier that “do not coincide with the dates when (he was) (..) hospitalized or treated in hospital,” the Office requested information from the aforementioned Authority (notes from XX, XX, and XX) to which a response was provided with the notes from XX, from XX, and from XX, in which it was particularly stated that: “From the investigations of the accesses, it emerged that out of 1309 (accesses), 780 were made by the interested party himself, who in this case is an employee of the health authority with a professional profile authorized to access the DSE itself”; “Regarding the overall number of accesses mentioned, it is noted that some of them were repeated in a very short time by the same operator for technical reasons and therefore should be considered as unique accesses, thus reducing the number of accesses to the DSE of the interested party.” From the list of accesses provided by the Authority, it appears that it has marked some as “unjustified” or limited to “only the list of healthcare services performed and not the related details,” regarding which it declared it would initiate “the necessary and consequential disciplinary proceedings”; “At present, if a clinical-administrative event is present in the system (hospitalization, access to the ER, specialist service), the healthcare operator is activated with the possibility of accessing the DSE. In situations where there is no clinical-administrative event, tracked at the computer level (e.g., a patient calling the professional for clarifications post-hospitalization), the healthcare operator has the possibility to access the DSE, by selecting a specific item from a predefined list which is as follows: In life-threatening/emergency; Prevention/diagnosis/treatment/rehabilitation on a patient in care but not registered in the computerized pathways provided”; “the healthcare operator can provide an additional specification to better justify access to the DSE. In the case of access via selection from the predefined list, the operator is required to confirm their choice with a simple electronic signature”; “The health authority has sent two circulars to healthcare operators, respectively in April and August of the current year, reiterating that the DSE is the tool that documents the health history of the interested party and can be consulted

exclusively by the healthcare personnel who takes care of the patient”;

“there will be an update of the authorizations for the processing of data as well as a first course scheduled for XX on the subject of “Protection of personal data and Digital Health”;

“healthcare professionals who operate exclusively in the administrative field, e.g., at the CUP, cannot access to the DSE, as healthcare operators, doctors, nurses, and other healthcare professionals operating within the forensic medicine service, the occupational medicine service, and medical management cannot access the DSE”; “Currently, the Health Authority has activated an automatic alert aimed at detecting anomalies in repeated accesses to the DSE in significant numbers”; the activation of a second alert is nearing completion, all specifically to prevent/identify any potential abuse as soon as possible”; “Regarding the question of whether employees of the Company can still access their health dossier with a healthcare profile, “the Company, following the sending of a relevant circular in April of this year, has proceeded to close access, starting from XX, for its employees with healthcare profiles to their DSE. Subsequently, with reference to the second complaint received from Mr. XX and regarding which the Company has issued a notification of violation on XX, subsequently supplemented on XX, it declared, in particular, that: between XX and XX “A total of 5 inappropriate accesses to the DSE (health dossier) of an interested party were executed”; “Two doctors and a nurse accessed the DSE of an interested party during the aforementioned time frame, namely: Doctor (A) XX; XX; XX; Doctor (B) XX; Nurse XX. On these occasions, it appears that the interested party was not taken in charge by the services in which these professionals are/were operating. Specifically, the Company contacted Doctor (A) and the nurse to obtain information on the reason for the access, and they highlighted the following: Doctor (A) reported being involved in the care process on XX by a doctor from the PS when the interested party actually accessed the PS. The nurse reported having performed Triage at the PS on XX but does not remember the access of XX. The Company has not yet been able to contact Doctor (B) as he is no longer operational in the Company and has requested the relevant contact details from the personnel office to seek clarifications.” Regarding the facts described above, the Company communicated to the interested party the aforementioned violation of personal data concerning him pursuant to Article 34 of the Regulation. In relation to the investigations described above, the Office, with note dated XX (prot. n. XX), ordered the consolidation of the proceedings and requested further information regarding the access methods to the dossier at the time of the events subject to the complaints, to which the Company represented, in particular, that: – “Between XX and XX, the list of reasons that allowed access to the health dossier included additional” cases, namely: “in life-threatening situations/emergency; prevention/diagnosis/treatment/rehabilitation of a patient in care but not registered in the computerized pathways provided; critical review for analysis and potential improvement of care pathways; process of sampling/transplantation; Medical Management: regulatory/organizational obligations; Cancer Registry: consultation. Following the initiation of data violation proceedings and the activation of alerts, the list has been reduced to the following: In life-threatening situations/emergency; Prevention/diagnosis/treatment/rehabilitation of a patient in care but not registered in the computerized pathways provided. The operator, therefore, currently can only choose between the two items mentioned above and subsequently, once one of them is chosen, has the possibility, within a free field, to note any further addition in terms of motivation for access”; – “From a further verification in association with the “illegal accesses,” there are no clinical administrative events recorded at the computerized level, in favor of the complainants”; – “an alert has been activated based on the number of accesses to the DSE of the individual interested party (number 0 exceeding 10) and for each operator, creating the conditions for determining a cross-check and in-depth verification of the activity of the involved operator.” Following these elements, the Office, with note dated XX (prot. n. XX), requested further information from the Company, which, with note dated XX, represented, in particular, that: “where consent to the processing of data through the dossier has not been expressed, access to this data is not permitted”; “The Company, considering the need to ensure that only the healthcare personnel involved in the care pathway of the interested party can access the DSE, has currently provided for the activation of alerts (automatic) as mentioned in our previous note.

Specifically, one alert is based on the number of accesses to the DSE of the individual interested party (number 0 exceeding 10) (already described and) (...) a second alert that automatically detects accesses to the DSE for which there are no active clinical administrative events (hospitalization, ongoing outpatient service/healthcare service in general, e.g., diagnostic examination), automatically highlighting the motivation from the list mentioned above, chosen by the operator accessing the DSE, as well as any further addition in terms of motivation for access that the operator might provide"; "The Company has planned the introduction and use of a new software "NGH" which will be operational throughout the Company by mid-next year and will operate in light of the guidelines adopted by management based on careful monitoring to be carried out by a specific Working Group on the DSE for this purpose.

"constituted";

regarding the various authorization profiles for access to the dossier provided within the Company, it has produced a table highlighting the depth of access to the dossier permitted for each type of operator;

with reference to the measures adopted to limit access to the dossier during the course of the care process, it has stated that "only in XX - 2 circulars were sent to all healthcare professionals regarding the correct use of the DSE; last year, targeted training was planned that will be implemented in FAD mode this year and will be administered to all operators authorized to access the DSE. Considering the high number and role of healthcare professionals who have access to the DSE (see attachments related to point 4), the Company, as mentioned above, has activated a working group formed by the privacy steering committee, the IT department, and representatives of the healthcare and technical assistance management to review access roles and the depth of access itself, all by XX. Currently, in order not to create a service disruption before closing default accesses, it is hoped to complete the aforementioned activity within the indicated timeframes in this document and to integrate this Note by XX in order to forward it to the Authority."

In relation to the findings of the aforementioned investigative activity, the Office, with act no. XX of XX, notified the Company, pursuant to Article 166, paragraph 5, of the Code, of the initiation of proceedings for the adoption of measures referred to in Article 58, paragraph 2, of the Regulation, inviting the aforementioned data controller to produce defensive writings or documents to the Guarantor or to request to be heard by the Authority (Article 166, paragraphs 6 and 7, of the Code; as well as Article 18, paragraph 1, of Law No. 689 of 24/11/1981).

Following the aforementioned notification, the Company sent its defensive memoranda with note of XX (prot. no. XX), requesting to be heard.

Subsequent to the hearing held on XX, the Company supplemented the documentation in the records with note of XX.

On the same date (XX), the Company also sent a new notification of violation pursuant to Article 33 of the Regulation concerning a case similar to those already subject to investigation. In particular, in this latest notification, it was communicated that a "staff member (healthcare professional)" accessed the health dossier of a patient, as well as their spouse, who was not under care with them during the period from XX to XX. Through such repeated accesses, the aforementioned professional viewed laboratory tests of their spouse outside of their care pathway and without their knowledge. According to what was stated in the aforementioned notification, the said professional was subjected to disciplinary proceedings.

In the cited notification, the Company also referred to what had already been represented in the communication sent on the same date to the Office regarding similar ongoing investigations related to the processing of data carried out through the corporate dossier.

In this regard, concerning the aforementioned notification made on XX regarding treatments similar to those already subject to investigation, the Office, with act no. XX of XX, recalling in full what had already been represented in the cited notification of violation of XX (prot. XX), ordered the consolidation of the ongoing investigative proceedings with that related to the notification presented by the Company on XX, noting - also for this case - pursuant to Article 166, paragraph 5, of the Code, that the configuration of the corporate health dossier was carried out in violation of the basic principles of processing referred to in Articles 5, paragraph 1, letters a), c), and f), 9, 25, and 32 of the Regulation,

inviting the aforementioned data controller to produce defensive writings or documents to the Guarantor or to request to be heard by the Authority (Article 166, paragraphs 6 and 7, of the Code; as well as Article 18, paragraph 1, of Law No. 689 of 24/11/1981).

Following the aforementioned notification, the Company sent further defensive memoranda with note of XX (prot. no. XX), requesting to be heard. The hearing took place remotely on XX.

In the referenced defensive memoranda (notes of XX, XX, and XX) and during the hearings of XX and XX, the Company particularly represented:

"the negligent nature of the violations";

with reference to the "latest episode notified to the Guarantor, the disciplinary procedure was suspended as the interested party informed the disciplinary committee of the formal complaint filed against them regarding the crime referred to in Article 615 ter of the Penal Code.";

"Following the initiation of the investigation by the Guarantor, the access methods to the corporate health dossier have been modified. Before the changes, there were two access methods: patient in care of the healthcare professional; self-declaration of the professional. The latter method will be deactivated and replaced with a documented assumption of care of the patient. Currently, an investigation is underway to gather clinicians' opinions regarding these changes concerning any impact in terms of care.";

"Specifically regarding self-declarations, the Company has decided to eliminate them as the illicit accesses occurred precisely through this method. At the same time, the Company aims to define specific care pathways to ensure that access to the dossier is not excluded for a clinician who has taken charge of the interested party.";

that it has proceeded to: "send to healthcare professionals during XX three circulars on the DSE; to" close the possibility of access to healthcare professionals to their own Electronic Health Record (EHR); to activate a specific working group on the EHR that involves all company departments as well as the IT division and the privacy steering committee; to forward to healthcare professionals further communication regarding the initiation of new access methods to the EHR (...); to reassess the existing alerts; to further review the depth of access for healthcare professionals; to prepare what is necessary for the launch, within the year, of a first basic course on data protection for all ASDAA employees, all in a bilingual and e-learning format";

that "the method of accessing the EHR via "Self-Certification" will be adjusted starting from XX with the aim of ensuring access to the EHR by healthcare professionals in such a way as to always trace the patient's care in light of the services provided and the clinical pathways activated, and only concerning those professionals actually involved in the patient's care pathway, without necessarily implying the physical presence of the patient in the facility (e.g., for specialist consultation, teleconsultation, televisit, clinical case evaluation, and scheduling of subsequent healthcare services)" (circular of XX);

The Company has also produced a document drafted in XX titled "ASDAA Health Dossier" in which the methods by which personal data is processed within the corporate health dossier have been described following the modifications made as a result of the initiation of the investigative activity by the Authority, with reference to which it has been stated that: "the purposes pursued through the establishment of the EHR are to be traced, for the Company, exclusively to the purposes of caring for the patient, namely prevention, diagnosis, treatment, and rehabilitation, excluding any other purpose. It is important to emphasize that, at the current state, the EHR of the South Tyrol Health Authority does not contain so-called highly sensitive data (i.e., relating to acts of sexual violence or pedophilia, HIV infection, pathological dependencies, services provided to women undergoing voluntary termination of pregnancy or who decide to give birth anonymously)";

the consent of the data subject is required for the establishment of the dossier and for the retrieval within it of data relating to events generated prior to the manifestation of consent;

with reference to access to the dossier, "The method of authorization and control of access to data and resources based on role and profile associates roles with each actor who needs to interact with the system. Each role defines a specific set of basic rights that the actor of that role can exercise, and roles are assigned based on the responsibilities inherent to the activities carried out within the

organization”;

“Access occurs by roles (professional profiles). Each role is allowed a specific scope of visibility consistent with its needs and competencies”;

“For healthcare professionals, the operational context of access to the EHR is determined by the role assigned to them, as well as by the status of the event or case being “open” or “closed” (hereinafter open and/or closed event) and by the belonging structure. Specifically, an open event or case refers to a service in progress (hospitalization, outpatient service, etc.) or one that is scheduled within the next 30 days or that has occurred within the previous 30 days. In the case of an open event: > Unit responsible for the patient: this is the unit that performs the service or that takes care of the predominant part (e.g., hospitalization, PAC, integrated outpatient, etc.). In general terms, the healthcare professional has access to all information contained in the EHR of the patient as long as the case remains open. They access events produced by the same unit without formalities. > Other Unit: in case of need for care (e.g., consultation, co-management of the case, and further cases listed below), in general terms, the healthcare professional accesses all information contained in the EHR of the patient in charge of another unit for a period related to the provision of the consultation (the consultation opening period is managed similarly to the event opening period). This is an event tracked by a specific computerized request (e.g., via Order Entry)”;

“In view of the unification of the various IT systems in use in the Company, scheduled for the end of XX, it is necessary to distinguish between contexts in which order entry is fully operational and contexts in which it is not yet operational everywhere,” with reference to which six cases have been foreseen: consultation, patient interview, Multidisciplinary Teleconsultation, Emergency, Request for Consultation from GP/PLS, Pre-admission;

automatic alerts have been activated regarding a data subject (more than 10 daily accesses to the dossier) capable of also detecting “the accesses to the EHR with respect to which events have been opened.”

With a note dated XX, the Office requested further information regarding the deadline by which “order entry” will be operational for all relevant contexts, the limits of temporal depth possibly foreseen with respect to access to the dossier by the professional roles indicated in the aforementioned document, and the technical-scientific reasons that would make it indispensable for the roles of speech therapist, ophthalmology assistant, podiatrist, dental hygienist, masseur and massage physiotherapist, and audiometric technician to access the multiple types of information indicated.

in the table 5 of the document "Health Dossier ASDAA", considering that the aforementioned document does not provide limits on the temporal depth of access to such information.

With a note dated XX, the Company responded to the aforementioned request for information stating, in particular, that:

there have been "further modifications compared to what was communicated on XX, modifications that will continue to be made, both in relation to the results of the working group itself, and in light of the progress of the activities for standardizing the company's IT system";

"to highlight the deadline by which this module will be fully operational for all reference contexts, one must refer to the dissemination plans of the Acceptance Discharge Transfer (ADT) and Emergency Room (PS) modules" from which "it can be inferred that the last activity to be completed according to the schedule will be (...) in the hospitals of Brunico and San Candido. (XX)", concluding on XX;

"it has been decided not to impose temporal limits on access for doctors (including dentists operating in the hospital context, provided that by the end of January XX access to the DSE for dentists operating only in the territorial context will be closed), on the other hand, temporal limits of two years have been established for the additional healthcare professions listed in the table below, all starting from XX";

"Within the framework of actions to improve the management of access depths carried out, an additional survey was conducted during the summer to refine the management of access depth to the DSE by interviewing the representatives of the relevant healthcare professions and analyzing the

access logs to the health dossier. After this survey, the access depth regarding the types of accessible documents has been reviewed and in most cases further limited. Regarding the aforementioned professions, the following changes have been made:

- Podiatrist: access to the DSE removed;
- Dental hygienist: access to the DSE removed;
- Physiotherapist and massage therapist: access to the DSE removed;
- Speech therapist: access to the DSE removed;
- Orthoptist-ophthalmology assistant: access to the DSE removed;
- Audiometric technician: access to the DSE removed";

The monitoring activity as highlighted above will continue, and there will certainly be changes both in terms of temporal access depth and mere access depth to the various documents listed in the table" already sent to the Authority, which has been resent in an updated manner.

2. Outcome of the investigative activity.

Preliminarily, it is stated that the processing of personal data must occur in compliance with the applicable regulations regarding personal data protection and, in particular, the provisions of Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016 (hereinafter, the "Regulation") and Legislative Decree No. 196 of June 30, 2003 (Code regarding the protection of personal data – hereinafter, the "Code").

With particular reference to the issue at hand, it is highlighted that personal data must be "processed lawfully, fairly, and transparently" (principle of "lawfulness, fairness, and transparency" and "in a manner that ensures adequate security (...), including protection against unauthorized or unlawful processing (principle of "integrity and confidentiality)") (art. 5, par. 1, lett. a) and f) of the Regulation).

Data must also be adequate, relevant, and limited to what is necessary in relation to the purposes for which they are processed (principle of data minimization) (art. 5, par. 1, lett. c) of the Regulation).

The Regulation further provides that the data controller must implement "appropriate technical and organizational measures to ensure a level of security appropriate to the risk," taking into account, among other things, "the nature, scope, context, and purposes of the processing, as well as the risk of varying probability and severity for the rights and freedoms of natural persons" (art. 32 of the Regulation).

With reference to the processing activities subject to this provision, the Authority has adopted the "Guidelines on Health Dossier - June 4, 2015" (Provision of 4.6.2015, published in G.U. 164 of July 17, 2015, available at www.gpdp.it/doc/web/n.4084632), which, like other provisions of the Authority, continue to apply even after the full implementation of the Regulation, as long as they are compatible with it (art. 22, paragraph 4, Legislative Decree No. 101/2018).

In the aforementioned Guidelines, the Authority, in order to prevent the risk of access to the information processed through the health dossier by unauthorized persons or the communication of health data to third parties by authorized persons, specifically requested the data controller to pay particular attention in identifying the authorization profiles and in training the authorized personnel, with access to the dossier being limited to only healthcare personnel involved in the patient's care process and adopting technical authentication methods to the dossier that reflect the access cases specific to each healthcare facility. To this end, in the aforementioned Guidelines, the Authority has indicated to the data controllers to monitor the instances in which the relevant healthcare personnel may need to consult the health dossier for care purposes.

of the company." This situation indicates a failure to implement adequate measures to restrict access to the health dossier solely to the healthcare personnel actively involved in the care of the patient.

2. Duration of access to the dossier. The access to the health dossier must be limited to the duration of the care process. However, the possibility of re-accessing the dossier should remain if necessary regarding the type of medical treatment to be provided to the interested party. The measures implemented by the Company did not sufficiently ensure that access was granted only during the time the healthcare personnel were involved in the patient's care.

3. Technical-organizational solutions. The holder must identify, in relation to the various functions assigned to the personnel, technical-organizational solutions that allow the administrative bodies of the health management to access a more complete information base than that present in the company's health dossier, within the limits of the attributions provided by law. The Company has not demonstrated that it has put in place such solutions to ensure comprehensive oversight of access to the health dossier.

4. Control systems for access. The Authority has emphasized the need for the holder of the treatment to implement systems for controlling access to the database and for detecting any anomalies that may constitute unlawful processing. The Company has not sufficiently addressed this requirement, as it has not activated specific alerts to identify anomalous or risky behaviors related to the operations performed by the data processors.

5. Compliance with previous directives. The Company was previously instructed to complete the implementation of specific measures to ensure that only healthcare professionals who were actively caring for the patient could access the health dossier. The Company has not fully complied with this directive, as evidenced by the ongoing access issues highlighted in the current proceedings.

6. Right to erasure. The Authority had also prescribed that the Company implement specific measures allowing the interested party to express the desire to erase individual clinical events from their health dossier, including those related to past events. The Company has not adequately addressed this requirement, which remains a critical area of concern.

In conclusion, the Company must take immediate action to rectify the identified deficiencies in access control, duration of access, technical-organizational solutions, and compliance with previous directives to ensure that the processing of personal data through the health dossier is lawful and respects the rights of the interested parties.

****Informatic**.** The modifications that the Company, following the notification of the violation referred to in Article 166, paragraph 5 of the Code, has declared it wishes to implement for access to the dossier exceed the critical issues identified during the investigation as follows: "the possibility of access for healthcare professionals to their own DSE" has been closed with the healthcare profile; "access occurs by roles (professional profiles). Each role is allowed a specific viewing scope consistent with their needs and competencies"; access to the dossier has been denied to the roles of speech therapist, ophthalmology assistant, podiatrist, dental hygienist, masseur, and physiotherapist technician. Such modifications, according to the statements made in the documents, will be in place for all relevant contexts by XX;

1. ****Alerts for anomalous access to the health dossier**.** Following the initiation of the investigation by the Authority, the Company has activated automatic alerts regarding the number of accesses and the control over the existence of an active clinical administrative event;

2. ****Purpose of the health dossier**.** Before the initiation of the investigation by the Authority, the Company had allowed access to the health dossier also by the medical management staff for "regulatory/organizational compliance" and for the "Cancer Registry: consultation". In this regard, it is highlighted that, given what was represented by the Authority in the aforementioned Guidelines, the holder must identify, in relation to the different functions assigned to the staff, specific profiles for access to the dossier also concerning the administrative bodies of the health management, so that they can access, within the limits of the attributions provided by law, a more complete information base than that present in the company health dossier. Given the right of obscuration exercisable by the interested party on the data present within the health dossier, this information tool may indeed not be complete. With specific reference to the Cancer Registry, it is noted that the methods of consultation of this Registry are expressly provided for by the sector regulations, on which the Authority has expressed its opinion, which does not foresee the use of the health dossier (Opinion on a draft decree pursuant to Article 12, paragraph 13 of the Decree-Law of October 18, 2012, No. 179, converted with amendments into Law December 17, 2012, No. 221, for the establishment of the National Cancer Registry - April 7, 2022, web doc No. 9773977). Following the initiation of the sanctioning procedure by

the Authority, the Company has represented that it has modified the cases of access to the dossier, pursuing with it "exclusively" "the purpose of caring for the patient, namely prevention, diagnosis, treatment, and rehabilitation, excluding any other purpose". On this point, it is noted that among the roles allowed access, the medical management and the Cancer Registry are no longer indicated.

3. Therefore, the configuration of the dossier at the time of the facts subject to investigation made it possible for healthcare personnel operating at the Company to access the health dossier of patients who were not - at the time of access - under their care, in violation of the basic principles of processing referred to in Articles 5, paragraph 1, letters a) and f) and 9 of the Regulation, as well as the principles of data protection by design and by default contemplated in Article 25 of the Regulation;

4. The Authority had already intervened on the processing of the data in question with the provision of July 3, 2014, in which it was prescribed, among other things, that the Company implement specific measures that would allow only healthcare professionals who are currently caring for the patient to access their health dossier for the duration of the care pathway. Such measures were to be adopted by October 31, 2014 (see deferral provision of September 11, 2014, web doc No. 3494478). The Company, in complying with the Authority's provision of 2014, identified technical and organizational measures that proved inadequate as, as demonstrated by the facts in question, they did not prevent healthcare personnel from accessing the health dossiers of patients they were not caring for and did not update such measures in light of the Authority's Guidelines of 2015 nor at the time of the full application of the Regulation;

5. The configuration of the dossier at the time of the facts subject to investigation did not provide for a system for detecting any anomalies that could constitute unlawful processing, nor the use of anomaly indicators (so-called alerts) aimed at identifying anomalous or risky behaviors related to the operations performed by the subjects authorized to process (e.g., number of accesses made, type or time frame of the same), useful for guiding subsequent audit interventions in violation of the principles of integrity and confidentiality of personal data (Articles 5, paragraph 1, letter f) and 32 of the Regulation);

6. The Company has illustrated in the notes in the documents the program for the adjustment of the information systems used by "all relevant contexts" which will conclude by XX.

****3. Conclusions.**** In light of the evaluations mentioned above, taking into account the statements made by the data controller during the investigation - and considering that, unless the fact constitutes a more serious crime, anyone who, in a proceeding before the Authority, falsely declares or certifies news or circumstances or produces false acts or documents...

****Response pursuant to Article 168 of the Code "Falsehood in declarations to the Guarantor and interruption of the execution of the tasks or the exercise of the powers of the Guarantor"***** - it is represented that the elements provided by the data controller in the defensive memoranda related to the aforementioned proceedings do not allow for overcoming the objections notified by the Office with the acts initiating the proceedings for the adoption of corrective and sanctioning measures, nor do any of the cases provided for in Article 11 of the Guarantor Regulation No. 1/2019 apply.

For these reasons, the illegality of the processing of personal data carried out by the Company in relation to the aforementioned proceedings initiated following communications of violations and complaints is noted, in the terms set out in the reasoning, in particular, for having processed personal data in violation of Articles 5, paragraph 1, letters a) and f), 9, 25, and 32 of the Regulation.

In this context, considering that a disciplinary procedure has been initiated and in one case also a criminal one against the author of the access and that the necessary adjustments have been made to overcome the aforementioned criticalities, the prerequisites for the adoption of the corrective measures referred to in Article 58, paragraph 2, of the Regulation do not exist.

****4. Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions (Articles 58, paragraph 2, letter i and 83 of the Regulation; Article 166, paragraph 7, of the Code).****

The violation of Articles 5, paragraph 2, letters a) and f), 9, 25, and 32 of the Regulation, caused by the

conduct of the Company, is subject to the application of the administrative pecuniary sanction pursuant to Article 83, paragraphs 4 and 5, of the Regulation.

Considering that the aforementioned proceedings concern the same data controller, similar personal data processing, occurring within the same time frame, and that the Company in the defensive memoranda related to the aforementioned proceedings has provided the same defensive elements, it is deemed appropriate to adopt the respective administrative sanctions in a single provision (Articles 10, paragraph 4, and 19 of the Guarantor Regulation No. 1/2019).

It should be noted that the Guarantor, pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, as well as Article 166 of the Code, has the power to “impose an administrative pecuniary sanction pursuant to Article 83, in addition to the [other] [corrective] measures referred to in this paragraph, or in lieu of such measures, depending on the circumstances of each individual case” and, in this context, “the Board [of the Guarantor] adopts the injunction order, which also provides for the application of the accessory administrative sanction of its publication, in whole or in part, on the Guarantor's website pursuant to Article 166, paragraph 7, of the Code” (Article 16, paragraph 1, of the Guarantor Regulation No. 1/2019).

The aforementioned administrative pecuniary sanction imposed, depending on the circumstances of each individual case, must be determined in amount taking into account the principles of effectiveness, proportionality, and deterrence, as indicated in Article 83, paragraph 1, of the Regulation, in light of the elements provided in Article 85, paragraph 2, of the Regulation in relation to which for both proceedings it is observed that:

- the Authority became aware of the event following two notifications of violation and two complaints (Article 83, paragraph 2, letter h) of the Regulation);
- with reference to all events subject to notification and complaint, the unlawful accesses concerned the health dossier of three patients by healthcare professionals who were not involved in their care process and against whom a disciplinary procedure has been initiated and in one case also a criminal one (Article 83, paragraph 2, letters a), b) and g) of the Regulation);
- in the case of the first and second complaint, which was also subject to notification of violation, the accesses were not justified by clinical reasons (two in the first case and five in the second) and occurred during the period XX, while in the case subject to the last notification of violation between XX and XX (access by an employee of the Company to the health dossier of their spouse without their knowledge) (Article 83, paragraph 2, letters a) and b) of the Regulation);
- the aforementioned accesses were possible because the measures in place regarding the processing of data suitable for revealing health information carried out through the company health dossier were not fully proportionate to ensure adequate security and integrity of personal data and to prevent unauthorized accesses, although the Authority had already intervened in this regard with the aforementioned provision of July 3, 2014, and subsequently with the Guidelines of 2015 (Article 83, paragraph 2, letters d) and e) of the Regulation);
- the Company has modified the methods and types of access to the company health dossier following the initiation of the investigation by the Authority, as well as introduced alert systems, cooperating with the Authority for this purpose (Article 83, paragraph 2, letters c) and f) of the Regulation);

In light of the aforementioned elements, evaluated in their entirety, it is deemed appropriate to determine the amount of the pecuniary sanction provided for by Article 83, paragraph 5, letter a) of the Regulation, for the violation of Articles 5, paragraph 1, letters a) and f), 9, 25, and 32 of the Regulation in the amount of:

- 25,000 (twenty-five thousand) for the procedure initiated following the complaint submitted by Mr. XX;
- 25,000 (twenty-five thousand) for the procedure initiated following the notification of violation of XX, subsequently supplemented on XX, and the complaint submitted by Mr. XX; and
- 25,000 (twenty-five thousand) for the procedure initiated following the notification of violation of XX;

as for the administrative monetary sanctions deemed, pursuant to Article 83, paragraph 1, of the Regulation, effective, proportionate, and dissuasive.

It is also considered that the accessory sanction of publication on the Garante's website of this provision, as provided for by Article 166, paragraph 7 of the Code and Article 16 of the Garante's Regulation no. 1/2019, should apply with reference to both proceedings examined, also in consideration of the type of personal data subject to unlawful processing.

Finally, it is noted that the conditions referred to in Article 17 of Regulation no. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Garante, are met.

ALL OF THE ABOVE, THE GARANTE

declares the unlawfulness of the processing of personal data carried out, in both the described proceedings, by the South Tyrol Health Authority, for the violation of Articles 5, paragraph 1, letters a) and f), 9, 25, and 32 of the Regulation as specified in the reasoning.

ORDERS

pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, as well as Article 166 of the Code, the South Tyrol Health Authority, Tax Code/VAT number 00773750211, to pay the total sum of €75,000 (seventy-five thousand) as follows:

the sum of €25,000 (twenty-five thousand) as an administrative monetary sanction for the violations detected in the context of the procedure initiated following the complaint filed by Mr. XX, indicated in this provision;

the sum of €25,000 (twenty-five thousand) as an administrative monetary sanction for the violations detected with the notification of violation of XX, subsequently supplemented on XX, and the complaint filed by Mr. XX, indicated in this provision;

the sum of €25,000 (twenty-five thousand) as an administrative monetary sanction for the violations detected with the notification of violation of XX, indicated in this provision;

according to the methods indicated in the annex, within 30 days from the notification in reasoning; it is represented that the offender, pursuant to Article 166, paragraph 8, of the Code, has the option to settle the dispute by payment, within the term of 30 days, of an amount equal to half of the imposed sanctions.

ORDERS

the aforementioned Company, in case of failure to settle the dispute pursuant to Article 166, paragraph 8, of the Code, to pay the total sum of €75,000 (seventy-five thousand) according to the methods indicated in the annex, within 30 days from the notification of this provision, under penalty of the adoption of the consequent executive acts in accordance with Article 27 of Law no. 689/1981.

DISPOSES

pursuant to Article 166, paragraph 7, of the Code, the full publication of this provision on the Garante's website and considers that the conditions referred to in Article 17 of Regulation no. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Garante, are met.

Pursuant to Article 78 of the Regulation, Articles 152 of the Code, and Article 10 of Legislative Decree no. 150/2011, it is possible to appeal against this provision before the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, February 22, 2024

THE PRESIDENT

Stanzione

THE REPORTER

Ghiglia

THE SECRETARY GENERAL

Mattei